

2. Assess the RDC strategic planning and the risk assessment process.

- Obtain and review the financial institution's strategic plan for the implementation of RDC.
- Review board or board committee minutes involving discussion and approval of RDC implementation. Note the date of approval.
- Summarize the key objectives of the strategic plan, including:
 - The rationale for offering RDC (e.g., maintaining existing customers or attracting new customers; maintaining existing geographic footprint or penetrating new market/geographic area; wholesale only [merchant/commercial] or retail [consumer]).
 - The type of RDC to be offered (e.g., thick vs. thin client) or if multiple types will be offered to a single client.
 - The use of technology service providers.
 - Other key objectives.
 - Describe the risk assessment process. Identify the financial institution's participants (e.g., representation from such functions as credit, IT, compliance, deposit operations, internal audit, and legal).
 - Obtain and review the most recent risk assessment related to RDC. Evaluate the quality of the risk assessment and whether it encompasses factors such as:
 - Scope of product implementation.
 - Type of customer (e.g., commercial, retail, foreign correspondent).
 - Type of cash letter instrument and the geographic location of the originator.
 - Financial institution position in payment process and settlement channels used (bank of first deposit vs. nonbank of first deposit).
 - Current and anticipated volume of RDC transactions (number and dollar amounts of transactions).
 - Customer role and responsibility in the RDC process.
 - Customer ability to download and retain nonpublic information (NPI).
 - Financial institution's approved technology service providers and equipment.
 - Clearing and settlement channels: image exchange, ACH, or both.
 - Ability to integrate RDC into:
 - Anti-money laundering systems and processes.
 - BCP.

- Information security planning.
- Staffing and customer support.
- Determine whether the RDC risk assessment is updated on a periodic basis as technology, market, customer base, industry, or processes change. Identify the date of the last risk assessment or update.

3. Customer due diligence and suitability.

- Describe the process, the financial institution staff involved, and the decision criteria the financial institution uses to conduct a due diligence review to qualify potential customers for the RDC delivery system. Consider the following:
 - The function and level of the financial institution's staff who conduct the due diligence, and those who have the authority to approve a customer for RDC;
 - How the financial institution risk rates existing customers, on a recurring basis, and how they qualify potential customers;
 - The information the financial institution reviews for potential customers such as:
 - Customer application.
 - Financial analysis.
 - Years in business (for commercial customers).
 - Loan/deposit history.
 - Credit score.
 - Business practices.
 - Sufficiency of staff.
 - Compliance with PCI standards (when appropriate).
 - Publicly available reports for customers that are companies (e.g., Dun & Bradstreet).
 - Visa/MasterCard terminated merchant file or ChexSystems reports, when appropriate to the customer
 - Whether the financial institution has procedures that address customer identification as explained in the BSA/AML manual.
 - Whether the financial institution has procedures to address foreign correspondent relationships and international cash letter pouch activity as explained in the BSA/AML manual.
 - Describe the process and criteria used by financial institution management to

evaluate the RDC customers' information security infrastructure and risk management processes.

4. Vendor Management

- Where technology service providers are used, determine whether RDC is included in the institution's vendor management program.
- Describe any service-level agreements between the financial institution and its service providers, and determine whether management of these relationships conforms to the Outsourcing Technology Services booklet.
- Determine whether any of the financial institution's RDC customers use a service provider in the RDC process. If so, evaluate how the financial institution manages risks, and whether the process is adequate.

5. Contracts and Agreements

- Determine whether legal counsel was involved in drafting any RDC-related contracts or agreements with technology service providers or customers.
- Obtain and review a sample contract or agreement between the financial institution and the RDC customer and technology service provider, where applicable. Consider whether contracts or agreements address the following:
 - Governing laws, regulations, guidelines, payment system rules, and other operational considerations relevant to traditional deposit processing.
 - Roles, responsibilities, and performance standards of the parties, including those related to the sale or lease of equipment needed for RDC at the customer location.
 - Liabilities, warranties, and indemnifications of all parties.
 - Types of items that may be transmitted.
 - Processes and procedures that the customer must follow (e.g., image quality).
 - Funds availability, collateral, collected funds, and reject/return requirements.
 - System maintenance and administration guidelines (e.g., change control and logical access administration).
 - Dispute resolution.
 - Information security requirements and procedures.
 - Security incident reporting.

- Customer service and technical support.
- Responsibility for network connectivity.
- Establishment of controls, such as deposit limits, overdraft limits, and payment on uncollected funds.
- Retention requirements and physical and logical security over deposit items and electronic files at the RDC customer location.
- Business continuity planning requirements, including the back-up of data and periodic testing of such plans.
- Limiting high-risk customers to one account for RDC.
- Authority of the financial institution to mandate specific internal controls at the customer's location(s); audits of customer operations; and requests for additional customer information, as necessary.
- Authority of the financial institution to terminate the RDC relationship.

6. Insurance

- Determine whether financial institution management assessed the availability, coverage, and suitability of insurance related to RDC. If coverage has been obtained, describe.

7. Physical and Logical Access Controls

- Describe how financial institution management ensures that appropriate physical security controls exist at the RDC customer location, such as:
 - Building security.
 - Check storage.
 - Ensuring appropriate controls over portable RDC-related equipment, such as computers and scanner equipment and software.
 - Transport mechanisms for moving data to off-site storage locations.
- Describe how financial institution management ensures that appropriate logical security controls exist at the RDC customer location, such as:
 - Encrypted data transmission and storage.
 - Multifactor or other strong authentication.
 - Access level controls.

- Password security parameters.
- Equipment enrollment.

8. Separation of Duties

- Describe how financial institution management has established appropriate separation of duties for the system administration and security monitoring functions. For example, does one person assign users or rights and another review the activity reports?
- Describe how the financial institution and its RDC customers have implemented appropriate separation of duties controls over the remote capture and transmission process.
- Determine whether the financial institution performs any data entry functions (e.g., adjusting dollar amounts), and whether there is an independent review or reconciliation.
- Determine whether the financial institution requires separation of duties at the RDC customer location and how it monitors for compliance. If separation of duties is not mandatory or possible, describe any required compensating controls required at the RDC customer location.

9. Oversight and Monitoring

- Obtain and review the financial institution's policies and procedures for RDC. Assess whether they define the function, responsibilities, operational controls, vendor management, customer due diligence, BSA/AML compliance monitoring, and reporting functions, etc. Identify the date they were last reviewed and approved by the board or a board committee.
- Identify the financial institution staff members who perform periodic monitoring of RDC customer activity and describe the process used.
- Determine the frequency and process for management review of logical and physical access privileges and audit trails/logs.
- Identify and describe the monitoring reports used by the financial institution to manage risk. Obtain copies of reports used and review the monitoring process with appropriate financial institution staff. Discuss with appropriate financial institution staff the internal processes for responding to established threshold breaches and any escalation process. Examples include:
 - Duplicate Presentment Report (to detect duplicate batches prior to submission);
 - Daily Batch Totals Report;

- Velocity Exception Report (to detect merchant spikes in volume or exceeding approved dollar limits);
- Large Item Report (exception report to detect whether transactions are outside of normal parameters); and,
- Customer Activity Report (detailed log of activity by merchant, including batch delivery date, time, value, receipt acknowledgement, and merchant operator ID).
- Identify and describe the RDC customer risk management reports recommended by financial institution management. Discuss how financial institution management validates that RDC customers review the reports. Examples include:
 - Pending Batch Report (items queued for processing for reasonableness and timeliness reviews);
 - Batch Total Report (allows the merchant to reconcile processed RDC work to the batch prepped for submission to the FI);
 - Return Item Report (alerts management to operational deficiencies, e.g., poor image quality);
 - Duplicate Presentment Report (to detect duplicate batches prior to submissions); and,
 - FI Reports (report would provide list of received imaged items).
- Select a sample of RDC customers and review the nature of account activity relative to the business type.

10. Training

- Determine whether financial institution management has established a training program to ensure that all parties involved are trained appropriately. If yes, describe the training programs for financial institution and customer staff.
- Determine whether the financial institution provides or plans to provide customer technical service or support to the RDC customers. If yes, discuss whether the financial institution considered the need for, or has added, additional staff.
- Determine whether the financial institution provides the merchant/consumer customers with a procedural or instructional document and a user guide for the application/scanner.

11. Change Management

- Determine whether the financial institution has enhanced its change management program to address the procedures involved in the RDC function and ensure ongoing compatibility between financial institution and customer systems. Describe the coordination process.
- If the financial institution maintains the application in-house, describe how it ensures that all relevant operating system and application patches are up-to-date.
- Describe how financial institution management ensures that RDC customers implement an effective change management program to maintain updated and patched network and desktop operating systems, RDC application, anti-virus, etc.

12. Records Management

Assess the process by which financial institution management verifies customer compliance with contract requirements related to the secure retention, storage, and destruction requirements for physical deposit items and electronic files.

13. Business Continuity Planning (BCP)

- Determine whether the financial institution's BCP has been updated to address:
 - The financial institution's relationship with the RDC service provider and BCP assurance.
 - The financial institution's relationship with the RDC customer.
 - Determine whether the financial institution's BCP testing activities include:
 - RDC systems and processes.
 - RDC customers.
 - Technology service providers, where appropriate.

14. Fraud

- Describe how financial institution management monitors for fraud associated with RDC.
- Describe how the financial institution attempts to mitigate fraud risks (e.g., duplicate check detection, establishing deposit limits, safeguarding checks).
- Describe how the financial institution monitors items that originated in foreign countries (i.e., foreign locations owned or controlled by customers of the financial institution or items received and processed by correspondent banks).

O. Vendor Management

Assess the adequacy of vendor management program over a service provider that provides a new and emerging retail payment technology. (Select one or more projects involving the development and deployment of a new and emerging retail payment technology and complete the following procedures.)

1. Review documentation supporting the business case for the application

- Scope and nature;
- Standards for controls;
- Minimum acceptable service provider characteristics;
- Monitoring and reporting;
- Transition requirements;
- Contract duration, termination, and assignment; and
- Contractual protections against liability.

2. Assess the extent to which the institution

- Reviews the financial stability of the technology service provider;
- Analyzes the service provider's audited financial statements and annual reports;
- Assesses the service provider's length of operation and market share;
- Considers the size of the institution's contract in relation to the size of the service provider;
- Reviews the service provider's level of technological expenditures to ensure on-going support; and
- Assesses the impact of economic, political, or environmental risk on the service provider's financial stability.

3. Evaluate whether the institution's due diligence considers the following:

- References from current users or user groups about a particular technology service provider's reputation and performance;
- The service provider's experience and ability in the industry;

- The service provider's experience and ability in dealing with situations similar to the institution's environment and operations;
- The cost for additional system and data conversions or interfaces presented by the various technology service providers;
- Shortcomings in the service provider's expertise that the institution would need to supplement in order to fully mitigate risks;
- The service provider's proposed use of third parties, subcontractors, or partners to support the outsourced activities;
- The service provider's ability to respond to service disruptions;
- Key service provider personnel that would be assigned to support the financial institution;
- The service provider's ability to comply with appropriate federal and state laws. In particular, ensure management has assessed the service providers' ability to comply with federal laws (including GLBA and BSA); and
- Country, state, or local risk.

4. Verify that the contract appropriately addresses:

- Scope of services;
- Performance standards;
- Pricing;
- Controls;
- Financial and control reporting;
- Right to audit;
- Ownership of data and programs;
- Confidentiality and security;
- Regulatory compliance;
- Indemnification;
- Limitation of liability;
- Dispute resolution;
- Contract duration;
- Restrictions on, or prior approval for, subcontractors;

- Termination and assignment, including timely return of data in a machine-readable format;
- Insurance coverage;
- Prevailing jurisdiction (where applicable);
- Choice of Law (foreign outsourcing arrangements);
- Regulatory access to data and information necessary for supervision; and
- Business Continuity Planning.

5. Review service level agreements to ensure they are adequate and measurable. Determine whether:

- Significant elements of the service are identified and based on the institution's requirements;
- Objective measurements for each significant element are defined;
- Reporting of measurements is required;
- Measurements specify what constitutes inadequate performance; and
- Inadequate performance is met with appropriate sanctions, such as reduction in contract fees or contract termination.

6. Evaluate the institution's periodic monitoring of the service provider relationship(s), including:

- Timeliness of review, given the risk from the relationship;
- Changes in the risk due to the function outsourced;
- Changing circumstances at the service provider, including financial and control environment changes;
- Conformance with the contract, including the service level agreement; and
- Audit reports and other required reporting addressing business continuity, security, and other facets of the outsourcing relationship.